

Cyber Fundamentals Coursework 1
WM179-18, Cyber Fundamentals (CF)
Coursework 1, MAINSIT

u6502780

1 Executive Summary

This report analyses the rising frequency and impact of cyber attacks on UK higher education. Astonishingly, 97% of universities faced cyber attacks in 2023–2024, with weekly attacks reported by 43% of universities. Notable cases include DDoS attacks and ransomware targeting Cambridge University, highlighting the destructive capabilities of unsophisticated actors. The report also analyses the October 2023 British Library cyber attack by Rhysida, revealing weaknesses in legacy systems, network complexity, and security practices. Recommendations include modernizing infrastructure, enhancing network segmentation, and improving staff cyber security training to build resilience against future threats.

2 Background

An alarming 97% of universities have identified breaches or attacks in the 2023-2024 period, 43% of which report cyber attacks at least weekly Maddy Ell (2024). The long-term impact on the quality of education caused by the halt of universities is vast and impossible to estimate. Since 1st October 2023, there have been three major publicly known attacks that I am going to talk about.

On Monday, 19th February 2024, University of Cambridge (2024), University of Wolverhampton (2024a), and University of Manchester (2024) reported IT outages due to an attack by the politically motivated group "Anonymous Sudan" Joe Tidy (2024). The University of Wolverhampton (2024b), in their message, even asked nearly thirty thousand students to stay home, which has impacted the quality of education.

It is concerning that even an unsophisticated threat actor like "Anonymous Sudan", which relies on simple attack methods executable by individuals with no technical skills Cloudflare (2024), can still manage to bring multiple universities offline.

Politically motivated attacks are not the only type of attacks being committed against universities. Four months after "Anonymous Sudan" attacked Cambridge with a DDoS attack, "INC Ransomware" targeted Cambridge University Press & Assessment publishing agency

on 29th June 2024 Pietro Melillo (2024a). The attackers threatened to publish sensitive information, which is a major disaster for an agency with an annual revenue of \$558.4 million. This is a reminder of how vulnerable even reputable institutions are to ransomware attacks.

Downtime and damage caused by ransomware attacks have a huge impact on the educational system not only in the UK but worldwide. The average cost per day of downtime in the US from 2018 to 2024 is more than half a million US dollars, with an average downtime of 12.55 days in 2023 Pietro Melillo (2024b). The report by SOPHOS (2024), which examines ransomware attacks in 14 countries, does not bring hope either. Half of all computers involved in higher education were impacted, with 79% and 68% of universities infected in 2023 and 2024, respectively. An alarming 67% of victims paid ransomware, with a median payment of \$4,410,000. The fact that ransoms are being paid encourages bad actors to keep targeting new victims. This is one of the reasons why NCSC (2024) recommends not paying ransoms.

3 Analysis of the British Library Cyber Attack

The cyber attack on the British Library in October 2023 exposed critical problems related to the library’s infrastructure and led to disruption in operation. Organised by the Rhysida ransomware group, the attack resulted in data encryption, exfiltration, and destruction of some servers to inhibit system recovery. This analysis examines the identity and methods of Rhysida as a threat actor and breaks down the stages of their attack using the Cyber Kill Chain. Additionally, it evaluates vulnerabilities within the library’s infrastructure that allowed Rhysida to deal with such an immense impact on all of the library’s systems.

3.1 Threat Actor Profile: Rhysida

Rhysida, identified as the criminal group responsible for the British Library cyber attack, operates as a sophisticated ransomware gang typically targeting large organizations. Their extortion tactics usually involve both encrypting data and threatening to publish sensitive

information on the dark web if a ransom is not paid. Rhysida’s usual targets include institutions with complex and outdated networks that have outgrown their owner’s ability to maintain them. They also target organisations holding valuable data for extortion, such as government agencies, educational institutions, and healthcare providers.

Rhysida combines traditional ransomware tactics with anti-forensic techniques, such as deleting log files and damaging servers to hinder recovery efforts and avoid detection. The group typically deploys phishing or spear-phishing campaigns to infiltrate systems, targeting privileged credentials or vulnerabilities within legacy infrastructure. Once inside, they escalate privileges to gain control over multiple systems, allowing them to encrypt vast amounts of data and maximise disruption. Prior incidents attributed to Rhysida have involved similar methods, including targeting organisations where legacy systems make full recovery challenging. This historical behaviour is useful in understanding the British Library attack’s progression and the vulnerabilities exploited by the group.

3.2 Attack Analysis Using the Cyber Kill Chain

The British Library cyber attack occurred in several phases, each corresponding to one of the steps described in the Cyber Kill Chain model. Understanding these phases provides insights into how Rhysida accessed the library’s systems, deployed ransomware, and maximised the impact of the intrusion.

3.2.1 Reconnaissance

The reconnaissance phase likely involved initial scans of the library’s network to identify weaknesses and gain an understanding of its infrastructure. Forensic investigations indicate signs of unauthorised access first detected on October 25, 2023. This initial breach was flagged by automated monitoring software, but no immediate action was taken beyond temporarily blocking the suspicious account. These early activities point to hostile reconnaissance aimed at mapping the network’s structure, identifying unprotected systems, and testing response protocols. By observing system responses to initial probing, Rhysida likely gathered the intelligence necessary to access privileged accounts later.

3.2.2 Weaponisation and Delivery

Rhysida’s next step was likely the development or deployment of malware to infiltrate the library’s infrastructure. The attack likely began through phishing or spear-phishing emails targeting privileged users, a common method for breaching organisational defenses. Large institutions like the British Library are particularly vulnerable to phishing due to high communication volumes, which make email filtration challenging.

Another possibility is the exploitation of known vulnerabilities within outdated systems lacking Multi-Factor Authentication (MFA). The absence of MFA on critical systems provided an easier route for Rhysida to escalate privileges once inside the network. Improper network segmentation allowed Rhysida to access multiple servers after the initial breach, enabling lateral movement through systems holding valuable data.

3.2.3 Installation

During the installation phase, Rhysida established control by deploying ransomware components to encrypt files and creating persistence mechanisms (backdoors) to maintain access and evade detection. Within days, key systems were compromised, data was encrypted, and administrative tools were manipulated to exfiltrate and destroy data. Rhysida exploited third-party management tools to create a persistent presence in the network.

3.2.4 Command and Control

Rhysida established command and control to issue directives, encrypt critical data, and exfiltrate information. The attack escalated during off-peak hours, notably the early hours of October 28, 2023, when 440 GB of sensitive data was transferred out of the library’s network. By this stage, Rhysida had full control over multiple systems, disabling critical services and executing ransomware.

3.3 Actions on Objectives

Rhysida achieved their primary objectives: encryption, data exfiltration, and infrastructure destruction. Over 600 GB of data became inaccessible, and core systems critical to the library's operations were disrupted. Rhysida not only encrypted data but also destroyed parts of the server infrastructure to hinder recovery. After the library refused to pay a ransom, Rhysida dumped the stolen data on the dark web, compounding the damage.

3.4 British Library Vulnerabilities

The British Library's infrastructure had multiple vulnerabilities that contributed to the attack's scale and severity. Key factors include:

- **Legacy Systems and Complex Infrastructure:** The widespread use of legacy systems meant software and databases lacked essential security measures, including regular patching and vendor support. This outdated infrastructure was highly vulnerable to ransomware attacks.
- **Third-Party Access and Network Complexity:** Reliance on numerous third-party providers for IT support created additional entry points. The complexity of managing permissions increased the risk, allowing Rhysida to exploit weak points.
- **Lack of Full Multi-Factor Authentication (MFA)** MFA was absent on several internal systems, providing an easy target for privilege escalation and network penetration.

3.5 Impact and Recovery

The attack's impact on the British Library was catastrophic, requiring extensive recovery efforts. Online services were inaccessible for months, and critical functions like the online catalogue were unavailable until January 2024. The *Rebuild & Renew* program, launched in December 2023, focused on modernising infrastructure, implementing security protocols, and creating a robust network architecture to prevent future

attacks. The reliance on legacy systems delayed recovery, underscoring the importance of maintaining secure and updated technology for critical public institutions.

4 Attach Graph

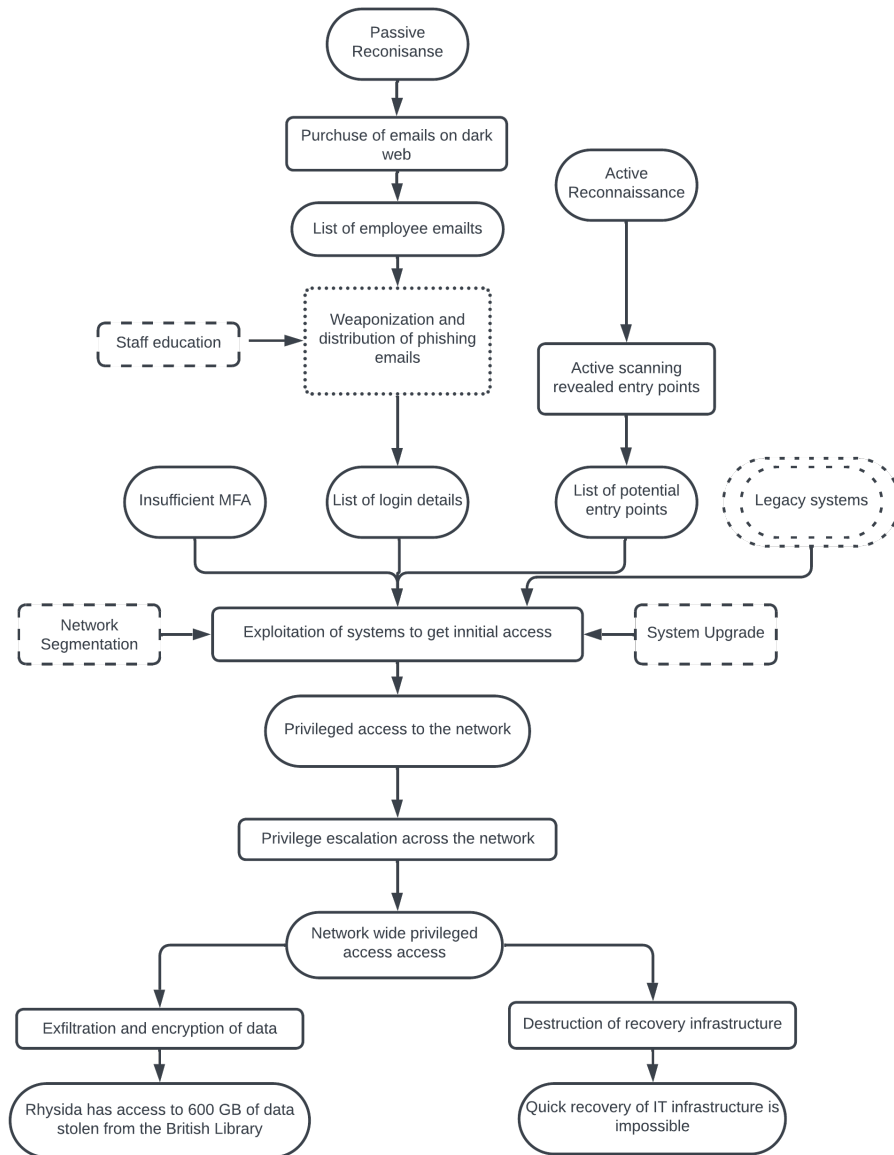


Figure 1: Attack Graph

5 Recommendations for Mitigating Future cyber attacks

To minimise the risk of future cyber attacks, the British Library should prioritise implementing the following three measures, given constraints placed by budget:

- **Modernisation of Legacy Systems:** Replacing or updating outdated systems is critical to addressing vulnerabilities exploited by Rhysida. Legacy systems lacked essential features like regular patching, vendor support, and Multi-Factor Authentication (MFA), which allowed attackers to escalate privileges and access sensitive systems. Modernised systems with built-in security measures will reduce attack surfaces, improve compatibility with updates, and enhance overall resilience. A phased upgrade plan can minimise disruption while prioritising the most vulnerable components.
- **Network Segmentation and Access Control:** The absence of network segmentation allowed Rhysida to move laterally and compromise multiple systems. Implementing segmentation will isolate critical systems, limiting an attacker's ability to access sensitive data from a single entry point. Stricter access controls, such as enforcing least privilege, can further reduce the damage potential. These measures strengthen the Library's defence-in-depth strategy and prevent attackers from navigating the network with ease.
- **Staff cyber security Training:** Human error likely played a role in Rhysida's successful phishing attacks, which were likely the entry points for the attack. Regular cyber security training for staff would address this vulnerability by improving awareness of phishing strategies, recognising suspicious emails, and adhering to best practices for password management.

References

- Cloudflare. What is anonymous sudan?, 2024. URL <https://www.cloudflare.com/en-gb/learning/ddos/glossary/anonymous-sudan/>.
- Joe Tidy. Hackers from anonymous sudan have disrupted internet connectivity, 2024. URL <https://x.com/joetidy/status/1759634685758406937>.
- Saman Rizvi Maddy Ell. Cyber security breaches survey 2024: education institutions annex, 2024. URL <https://www.gov.uk/government/statistics/cyber-security-breaches-survey-2024/cyber-security-breaches-survey-2024-education-institutions-annex>.
- NCSC. Guidance for organisations considering payment in ransomware incidents, 2024. URL <https://www.ncsc.gov.uk/files/Guidance-for-organisations-considering-payment-in-ransomware-incidents.pdf>.
- Pietro Melillo. Cambridge university press assessment ends up in the dls of inc ransomware, 2024a. URL <https://www.redhotcyber.com/en/post/cambridge-university-press-assessment-ends-up-in-the-dls-of-inc-ransomware/>.
- Pietro Melillo. On average, us schools colleges lose 500kperdaytodowntimefromransomwareattach
- SOPHOS. The state of ransomware 2024, 2024. URL <https://assets.sophos.com/X24WTUEQ/at/9brgj5n44hqvgsp5f5bqcps/sophos-state-of-ransomwar.pdf>.
- University of Cambridge. Multiple universities have reported a malicious denial of service attack, 2024. URL https://x.com/Cambridge_CSCS/status/1759618745046020236.
- University of Manchester. Cyber incident: Ongoing network connectivity issues, 2024. URL <https://x.com/OfficialUoM/status/1759719477850108349>.
- University of Wolverhampton. University of wolverhampton asks students and staff to work from home due to it issue, 2024a. URL <https://x.com/OfficialUoW/status/1759719477850108349>.

//www.facebook.com/uniwolverhampton/posts/due-to-a-systems-issue-across-all-of-785853770240655/.

University of Wolverhampton. Key facts about university of wolverhampton, 2024b. URL <https://www.wlv.ac.uk/university-life/key-facts/>.